

# Relazione Tecnica di Penetration Testing

## Analisi di Sicurezza Offensiva su Infrastruttura di Laboratorio Controllato: Caso di Studio “Jangow01”

Corso: Cybersecurity e Penetration Testing

Tipologia di documento: Relazione tecnico-accademica di esercitazione pratica

Ambiente: Laboratorio isolato (rete privata 192.168.1.0/24), macchina target virtualizzata

Data di redazione: 30 luglio 2026

### Disclaimer Etico e Metodologico

La presente relazione documenta un'attività di ethical hacking condotta esclusivamente a fini didattici, nell'ambito di un percorso formativo universitario in sicurezza informatica. L'intera esercitazione è stata svolta in un ambiente di laboratorio isolato e controllato, costituito da una macchina virtuale appositamente predisposta per finalità di apprendimento (target identificato dall'indirizzo IP privato 192.168.1.13, non instradabile su rete pubblica).

Nessuna delle tecniche, degli strumenti o delle procedure descritte è stata applicata, né è replicabile, contro sistemi di produzione, infrastrutture reali o soggetti terzi privi di autorizzazione esplicita. La riproduzione delle metodologie qui illustrate al di fuori di un contesto autorizzato costituisce violazione della normativa vigente in materia di accesso abusivo a sistemi informatici (art. 615-ter c.p. e normative equivalenti in altre giurisdizioni).

## **Abstract**

Il presente elaborato descrive un'attività di penetration testing condotta su una macchina virtuale di laboratorio, con l'obiettivo di identificare, sfruttare e documentare le vulnerabilità presenti in un'infrastruttura web basata su stack Apache/PHP/MySQL, fino al conseguimento di privilegi amministrativi (root) sul sistema operativo sottostante.

La metodologia adottata ricalca le fasi canoniche di un test di intrusione (reconnaissance, scanning, enumeration, exploitation, privilege escalation), in coerenza con framework di riferimento quali il Penetration Testing Execution Standard (PTES) e la matrice MITRE ATT&CK. Il percorso di attacco ha evidenziato una catena di vulnerabilità concatenate — esposizione di directory listing, una funzionalità di ricerca vulnerabile a OS Command Injection, credential exposure tramite file di backup non protetti e, infine, un difetto del kernel Linux sfruttabile per l'escalation dei privilegi — che, nel loro insieme, hanno consentito la compromissione totale del sistema.

La relazione si conclude con un'analisi dei rischi strutturata secondo criteri di probabilità e impatto, un set di contromisure tecniche e organizzative allineate agli standard Zero Trust, e una riflessione finale sulle lezioni apprese, coerentemente con gli obiettivi formativi dell'esercitazione.

## Indice

## 1. Introduzione

La sicurezza informatica costituisce oggi un pilastro strategico per la continuità operativa di qualsiasi organizzazione, non più relegabile a mera funzione tecnica accessoria. Come evidenziato dalla letteratura di settore più recente, la superficie di attacco delle infrastrutture moderne si è progressivamente ampliata a causa della trasformazione digitale, dell'adozione di architetture ibride e multi-cloud e della crescente sofisticazione degli attori di minaccia. In tale contesto, l'attività di penetration testing rappresenta uno strumento fondamentale di verifica proattiva della postura di sicurezza, poiché consente di identificare le vulnerabilità prima che queste possano essere sfruttate da attori malevoli.

La presente relazione si colloca in un percorso di formazione pratica in sicurezza offensiva e documentata, in maniera sistematica e riproducibile, l'intero processo di analisi condotto su una macchina target di laboratorio. L'obiettivo didattico primario è duplice: da un lato, consolidare la padronanza degli strumenti e delle metodologie tipiche del penetration testing; dall'altro, sviluppare una comprensione critica delle cause profonde (root cause) delle vulnerabilità riscontrate, propedeutica alla formulazione di adeguate strategie di difesa.

## 2. Obiettivi dell'Esercitazione e Contesto Operativo

L'esercitazione si prefigge i seguenti obiettivi specifici:

| Obiettivo | Descrizione                                                                                    |
|-----------|------------------------------------------------------------------------------------------------|
| O1        | Effettuare la ricognizione della rete e l'identificazione dell'host target                     |
| O2        | Enumerare i servizi esposti e le relative versioni                                             |
| O3        | Individuare risorse e directory non pubblicizzate del server web                               |
| O4        | Identificare vulnerabilità applicative sfruttabili per l'esecuzione di comandi remoti          |
| O5        | Ottenere un accesso a livello di sistema operativo (shell utente)                              |
| O6        | Elevare i privilegi fino al livello amministrativo (root)                                      |
| O7        | Documentare l'intero processo secondo criteri di tracciabilità e riproducibilità professionale |

Il target dell'esercitazione è un host identificato all'interno della rete di laboratorio (192.168.1.0/24) con indirizzo IP 192.168.1.13, hostname rilevato "blackbox", ospitato su infrastruttura di virtualizzazione (Oracle VirtualBox). L'attacco è stato condotto da una postazione Kali Linux (192.168.1.10), dotata degli strumenti standard per l'attività di offensive security.

## 3. Metodologia Adottata

L'attività è stata condotta seguendo un approccio strutturato in fasi sequenziali, in linea con i principali standard metodologici di settore (PTES, OSSTMM), articolato come segue:

1. Network Discovery: identificazione degli host attivi sulla subnet.
2. Scanning ed Enumeration: rilevamento di porte, servizi e versioni software esposte.

3. Web Application Enumeration: individuazione di percorsi, file e componenti applicativi non direttamente collegati dall'interfaccia principale.
4. Vulnerability Assessment: analisi manuale delle componenti individuate al fine di identificare debolezze sfruttabili.
5. Exploitation: sfruttamento controllato delle vulnerabilità identificate per la dimostrazione dell'impatto reale.
6. Post-Exploitation e Privilege Escalation: consolidamento dell'accesso ed elevazione dei privilegi.
7. Reporting: documentazione strutturata di ciascuna fase, corredata da evidenze (output di comando e catture schermo).

Per ciascuna fase sono stati impiegati strumenti open source consolidati nel settore, tra cui netdiscover, nmap, gobuster, curl, un client FTP a riga di comando e uno script di enumerazione locale (linpeas.sh).

## 4. Fase 1 – Ricognizione e Network Discovery

### 4.1 Obiettivo

Individuare gli host attivi all'interno del segmento di rete di laboratorio, al fine di identificare univocamente il sistema target.

### 4.2 Comando Utilizzato

```
sudo netdiscover -r 192.168.1.0/24
```

### 4.3 Risultati

La scansione ARP ha permesso di identificare l'host target, con indirizzo IP 192.168.1.13 e hostname "blackbox".

### 4.4 Analisi

L'esito della fase di discovery ha fornito l'informazione minima indispensabile — l'indirizzo IP del bersaglio — per procedere alle fasi successive di enumerazione attiva. Trattandosi di un ambiente di laboratorio con un unico host di interesse, la fase non ha richiesto ulteriori approfondimenti.

## 5. Fase 2 – Port Scanning e Service Enumeration

### 5.1 Obiettivo

Determinare le porte TCP aperte sull'host target, i servizi in ascolto e le rispettive versioni software, al fine di individuare potenziali vettori di attacco.

### 5.2 Comando Utilizzato

```
sudo nmap -sV -sC -p- 192.168.1.13
```

L'opzione `-p` estende la scansione all'intero spazio delle porte TCP (1–65535); `-sV` abilita il rilevamento delle versioni dei servizi; `-sC` esegue il set di script predefiniti (default scripts) di Nmap.

### 5.3 Risultati

La scansione ha rilevato due porte aperte:

| Porta  | Servizio | Versione                     | Note                                                                   |
|--------|----------|------------------------------|------------------------------------------------------------------------|
| 21/tcp | FTP      | vsftpd 3.0.3                 | —                                                                      |
| 80/tcp | HTTP     | Apache httpd 2.4.18 (Ubuntu) | Directory listing attivo ("Index of /"), con una sotto-directory site/ |

*Figura 1 – Output completo della scansione Nmap (`-sV -sC -p-`) sull'host 192.168.1.13, con evidenza dei servizi FTP e HTTP esposti e del directory listing abilitato.*

### 5.4 Analisi

Il rilevamento del directory listing abilitato sulla porta 80 costituisce, di per sé, un primo indicatore di debolezza nella configurazione del server web, poiché espone la struttura delle directory a chiunque acceda al servizio senza necessità di autenticazione o di conoscenza pregressa dei percorsi. Tale informazione ha guidato l'orientamento della successiva fase di enumerazione verso il percorso `/site/`.

Una verifica preliminare tramite `curl -v` ha confermato quanto rilevato da Nmap, restituendo il codice di stato HTTP 200 e il contenuto della pagina indice, contenente il collegamento alla directory `site/`.

*Figura 2 – Richiesta HTTP manuale (`curl -v`) alla radice del server, con conferma del directory listing e del collegamento alla sotto-directory `site/`.*

## 6. Fase 3 – Enumerazione delle Risorse Web

### 6.1 Obiettivo

Identificare, tramite tecniche di directory e file brute-forcing, risorse non direttamente collegate dall'interfaccia visibile dell'applicazione, potenzialmente indicative di componenti aggiuntivi o mal configurati.

### 6.2 Comandi Utilizzati e Risultati Progressivi

**Enumerazione della radice del server:**

```
gobuster dir -u http://192.168.1.13/ -w /usr/share/wordlists/dirb/common.txt
```

È stata identificata la directory `site/` (codice di stato 301).

*Figura 3 – Enumerazione delle directory sulla radice del server: identificazione della risorsa `site/`.*

**Enumerazione della directory `/site/`:**

```
gobuster dir -u http://192.168.1.13/site/ -w /usr/share/wordlists/dirb/common.txt
```

Sono state individuate le sotto-directory assets/, css/, js/, wordpress/, oltre al file index.html.

*Figura 4 – Enumerazione della directory /site/, con individuazione della sotto-directory wordpress/, successivamente rivelatasi critica ai fini dell'attacco.*

Un'ispezione manuale del codice sorgente della pagina indice (curl -s http://192.168.1.13/site/ | head -100) ha confermato l'utilizzo del tema Bootstrap “Grayscale” e la presenza di un modulo di ricerca (busque.php), elemento che si sarebbe successivamente rivelato determinante ai fini dell'exploitation.

*Figura 5 – Estratto del codice sorgente HTML della pagina applicativa, con evidenza del collegamento alla funzionalità di ricerca busque.php.*

### Enumerazione con estensioni multiple:

```
gobuster dir -u http://192.168.1.13/site/ -x php,html,txt,zip -w /usr/share/wordlists/dirb/common.txt
```

La scansione con estensioni non ha prodotto risultati aggiuntivi significativi rispetto all'iterazione precedente, confermando tuttavia la struttura già identificata.

*Figura 6 e Figura 7 – Verifica della directory /site/wordpress/ (richiesta manuale) ed enumerazione con estensioni multiple (php, html, txt, zip) della directory /site/.*

### Enumerazione mirata della directory /site/wordpress/:

```
gobuster dir -u http://192.168.1.13/site/wordpress/ -x php,html,txt,zip,log,sql -w /usr/share/wordlists/dirb/common.txt
```

La scansione ha rilevato la presenza del file config.php (codice di stato 200, dimensione 87 byte), tipicamente associato alla memorizzazione dei parametri di connessione al database.

*Figura 8 – Enumerazione della directory /site/wordpress/: identificazione del file config.php, elemento chiave per la successiva fase di analisi.*

## 6.3 Analisi

L'individuazione del file config.php accessibile pubblicamente rappresenta un'anomalia significativa: in un'installazione WordPress correttamente configurata, tale file, se interpretato dal motore PHP, non dovrebbe restituire alcun output visibile al client, in quanto il suo contenuto è costituito da direttive di configurazione elaborate lato server. La ridotta dimensione della risposta (87 byte) e il contenuto restituito, come illustrato nella sezione seguente, hanno indicato la presenza di un errore di connessione al database esposto direttamente al richiedente, configurando un caso di information disclosure.

## 7. Fase 4 – Identificazione e Sfruttamento della Vulnerabilità di Command Injection

### 7.1 Obiettivo

Analizzare il comportamento anomalo del file config.php e della funzionalità di ricerca busque.php, al fine di determinare l'esistenza di vulnerabilità sfruttabili per l'esecuzione di comandi arbitrari sul sistema remoto.

## 7.2 Osservazione Iniziale: Errore di Connessione al Database

La richiesta diretta al file config.php ha restituito il seguente messaggio d'errore, generato dal driver mysqli di PHP:

```
Connection failed: Access denied for user 'desafio02'@'localhost' (using password: YES)
```

*Figura 9 – Verifica tramite browser del messaggio di errore restituito da config.php, indicativo di un tentativo di connessione al database fallito e di conseguente esposizione di informazioni diagnostiche.*

Tale evidenza ha confermato la presenza di un nome utente di database (desafio02) e ha suggerito l'esistenza di credenziali di accesso memorizzate nel medesimo file, non direttamente estraibili tramite la sola richiesta HTTP a causa della corretta interpretazione lato server dello script PHP in quella specifica configurazione di accesso.

## 7.3 Individuazione della Funzionalità di Ricerca Vulnerabile

L'analisi del collegamento “Buscar” presente nella pagina indice ha condotto all'identificazione dello script busque.php, il quale espone un parametro GET (buscar) utilizzato per l'esecuzione di comandi di sistema (verosimilmente tramite funzioni PHP quali shell\_exec() o equivalenti), senza alcuna forma di validazione, sanificazione o escaping dell'input fornito dall'utente.

```
http://192.168.1.13/site/busque.php?buscar=ls
```

*Figura 10 – Verifica della vulnerabilità di OS Command Injection nello script busque.php: il parametro buscar restituisce l'output del comando di sistema ls eseguito lato server.*

## 7.4 Sfruttamento della Vulnerabilità

Sfruttando la vulnerabilità identificata, è stato possibile localizzare ed esfiltrare il contenuto del file di configurazione, aggirando la protezione data dall'interpretazione diretta dello script PHP:

```
curl -s  
"http://192.168.1.13/site/busque.php?buscar=find%20/%20-name%20config.php%20>/dev/null"  
curl -s  
"http://192.168.1.13/site/busque.php?buscar=cat%20/var/www/html/site/wordpress/config.php"
```

L'esecuzione dei comandi ha restituito il percorso assoluto del file (/var/www/html/site/wordpress/config.php) e, successivamente, il suo contenuto integrale in chiaro:

```
$servername = "localhost";  
$database   = "desafio02";  
$username   = "desafio02";  
$password   = "abygur169";
```

*Figura 11 – Sfruttamento della command injection per la localizzazione (comando find) e l'esfiltrazione (comando cat) del contenuto del file config.php, con esposizione delle credenziali del database applicativo.*

Nel corso dell'analisi manuale del codice sorgente della risposta, è stata inoltre osservata — tramite lo strumento di ispezione del browser — un'ulteriore condizione di source code disclosure: il



contenuto testuale del file di configurazione risultava visibile anche come commento HTML non interpretato, a conferma della fragilità complessiva della gestione dei contenuti dinamici da parte dell'applicazione.

*Figura 12 – Ispezione del DOM tramite gli strumenti di sviluppo del browser: il codice sorgente PHP del file di configurazione risulta esposto come testo non interpretato, confermando l'assenza di adeguati controlli sulla gestione dell'output.*

## 7.5 Individuazione di Credenziali Aggiuntive tramite File di Backup

Proseguendo l'enumerazione del file system tramite la medesima vulnerabilità di command injection, è stata individuata, nella directory radice del web server, la presenza di un file nascosto denominato .backup:

```
http://192.168.1.13/site/busque.php?buscar=ls%20-la%20/var/www/html/
```

*Figura 13 – Enumerazione del contenuto della directory radice del web server tramite command injection: individuazione del file nascosto .backup, di proprietà dell'utente www-data.*

L'estrazione del contenuto del file ha rivelato un secondo insieme di credenziali, riferite a un diverso database e, presumibilmente, a un differente utente di sistema:

```
curl -s "http://192.168.1.13/site/busque.php?buscar=cat%20/var/www/html/.backup"
$database = "jangow01";
$username = "jangow01";
$password = "abygur169";
```

*Figura 14 – Contenuto del file .backup, contenente credenziali riferite all'utenza di sistema jangow01, riutilizzata come vettore di accesso alla macchina.*

## 7.6 Analisi

La catena di vulnerabilità identificata in questa fase è particolarmente significativa dal punto di vista didattico, poiché dimostra come debolezze apparentemente minori — un messaggio di errore verboso, un file di backup dimenticato, un parametro di ricerca privo di validazione — possano, se concatenate, produrre un impatto di sicurezza severo. In particolare, la vulnerabilità di OS Command Injection riscontrata in `busque.php` è classificabile, secondo la tassonomia OWASP, come CWE-78 (Improper Neutralization of Special Elements used in an OS Command), e ha costituito il fulcro dell'intera catena di compromissione, in quanto ha consentito l'esecuzione di comandi arbitrari con i privilegi dell'utente del servizio web (`www-data`).

## 8. Fase 5 – Accesso al Sistema tramite Servizio FTP

### 8.1 Obiettivo

Verificare il riutilizzo delle credenziali individuate per l'ottenimento di un accesso interattivo al sistema, sfruttando il servizio FTP precedentemente identificato in fase di scansione.

### 8.2 Comando Utilizzato

```
ftp 192.168.1.13
```

Le credenziali jangow01 / abygurl69, individuate nel file .backup, sono state impiegate come tentativo di autenticazione, ipotizzando un riutilizzo delle credenziali tra il contesto applicativo e quello del sistema operativo — pratica non conforme ai principi di separation of duties e di gestione sicura delle identità.

### 8.3 Risultati

L'autenticazione è stata completata con successo ("230 Login successful"), confermando l'ipotesi di riutilizzo delle credenziali. La successiva navigazione nella home directory dell'utente (/home/jangow01) ha permesso di individuare il file user.txt, elemento probatorio convenzionalmente utilizzato negli esercizi di Capture The Flag per attestare il raggiungimento del livello di accesso utente.

*Figura 15 – Sessione FTP autenticata con le credenziali jangow01, con elenco del contenuto della home directory e individuazione del file user.txt.*

Al fine di proseguire l'attività di enumerazione locale del sistema, è stato effettuato il caricamento dello script linpeas.sh tramite il medesimo canale FTP. Un primo tentativo di caricamento nella home directory dell'utente non è andato a buon fine per assenza dei permessi di scrittura necessari; il file è stato pertanto trasferito con successo nella directory temporanea di sistema (/tmp), dotata di permessi di scrittura più permissivi.

*Figura 16 – Trasferimento dello script di enumerazione locale linpeas.sh tramite protocollo FTP verso la directory /tmp del sistema target.*

### 8.4 Analisi

Il successo dell'autenticazione FTP con credenziali derivate dal contesto applicativo costituisce una conferma empirica di una prassi di sicurezza scorretta, ovvero il riutilizzo delle medesime credenziali tra utenze di servizio (database) e utenze di sistema operativo. Tale pratica amplifica in maniera sostanziale l'impatto di una singola violazione, trasformando una fuga di informazioni applicativa in un vettore di accesso diretto al sistema operativo sottostante.

## 9. Fase 6 – Escalation dei Privilegi

### 9.1 Obiettivo

A partire dall'accesso utente ottenuto (jangow01), individuare ed eseguire un exploit idoneo all'elevazione dei privilegi fino al livello amministrativo (root), completando così la catena di compromissione totale del sistema.

### 9.2 Metodologia

L'enumerazione locale, condotta anche con il supporto dello script linpeas.sh precedentemente trasferito, ha permesso di individuare informazioni relative alla versione del kernel Linux in esecuzione sul sistema target, risultata vulnerabile a una nota falla di sicurezza relativa al sottosistema eBPF (extended Berkeley Packet Filter), corrispondente all'exploit pubblicamente documentato con identificativo Exploit-DB 45010 (riconducibile alla vulnerabilità CVE-2017-16995).

### 9.3 Comandi Utilizzati

```
gcc -o exploit 45010.c
chmod +x exploit
./exploit
```

### 9.4 Risultati

L'esecuzione dell'exploit ha avviato una sequenza di operazioni a basso livello, comprendenti la creazione di una mappa BPF, l'iniezione di un modulo BPF malevolo oltre i controlli del verificatore del kernel (verifier bypass), la creazione di una coppia di socket per la manipolazione della memoria del kernel e, infine, la modifica diretta della struttura delle credenziali (cred structure) del processo in esecuzione, sostituendo l'identificativo utente (UID) con il valore corrispondente all'utenza privilegiata di sistema.

L'esito dell'operazione è stato verificato tramite i comandi `whoami` e `getuid`, che hanno confermato l'acquisizione di una shell con privilegi root.

*Figura 17 – Compilazione ed esecuzione dell'exploit per l'escalation dei privilegi (Exploit-DB 45010, vulnerabilità eBPF): la sequenza di output conferma la manipolazione della struttura delle credenziali del kernel e il conseguimento di una shell con privilegi amministrativi (whoami → root).*

### 9.5 Analisi

Il conseguimento dei privilegi di root rappresenta il traguardo conclusivo dell'esercitazione e dimostra come una vulnerabilità del kernel, se non tempestivamente corretta mediante l'applicazione delle patch di sicurezza rilasciate dal fornitore, possa vanificare qualunque misura di segregazione dei privilegi implementata a livello applicativo. La circostanza per cui l'accesso iniziale a basso privilegio sia stato sufficiente, in assenza di ulteriori controlli compensativi, per raggiungere il pieno controllo del sistema, evidenzia una carenza sistemica nella gestione del ciclo di vita degli aggiornamenti di sicurezza (patch management).

## 10. Analisi dei Rischi e Contromisure

La presente sezione approfondisce, in chiave sistematica, i rischi individuati nel corso dell'esercitazione, valutandone la severità secondo i criteri di probabilità di sfruttamento e impatto potenziale, e associando a ciascuna vulnerabilità le relative contromisure tecniche e organizzative.

### 10.1 Quadro Sinottico delle Vulnerabilità Identificate

| ID | Vulnerabilità                                             | Classificazione | Probabilità | Impatto | Rischio |
|----|-----------------------------------------------------------|-----------------|-------------|---------|---------|
| V1 | Directory listing abilitato su Apache                     | CWE-548         | Alta        | Basso   | Medio   |
| V2 | Esposizione di percorsi e file (config.php raggiungibile) | CWE-200         | Alta        | Medio   | Alto    |
| V3 | Messaggi di errore verbosi del database esposti al client | CWE-209         | Alta        | Medio   | Alto    |
| V4 | OS Command Injection nel parametro buscar                 | CWE-78          | Alta        | Critico | CRITICO |

| ID | Vulnerabilità                                                             | Classificazione | Probabilità | Impatto | Rischio |
|----|---------------------------------------------------------------------------|-----------------|-------------|---------|---------|
| V5 | File di backup con credenziali in chiaro nella document root              | CWE-538         | Media       | Critico | CRITICO |
| V6 | Riutilizzo credenziali tra utenza applicativa e di sistema                | CWE-798         | Media       | Alto    | Alto    |
| V7 | Kernel non aggiornato, vulnerabile a escalation via eBPF (CVE-2017-16995) | CWE-269         | Media       | Critico | CRITICO |

## 10.2 Analisi Approfondita per Categoria di Rischio

### Rischio applicativo (V2, V3, V4).

La causa radice della compromissione risiede in un difetto architetturale della applicazione web: l'assenza di validazione dell'input utente in un contesto di esecuzione di comandi di sistema. Tale difetto, unito alla configurazione eccessivamente permissiva del server (assenza di restrizioni sui percorsi accessibili e sui messaggi di errore restituiti), ha reso possibile una escalation progressiva da una semplice enumerazione di directory fino all'esecuzione di comandi arbitrari. In termini di attack surface, si osserva come la presenza di funzionalità di ricerca "custom", sviluppate al di fuori di framework consolidati e privi di meccanismi di sanificazione dell'input, rappresenti un vettore ricorrente nelle applicazioni web sviluppate senza l'adozione di pratiche di secure coding.

### Rischio di gestione delle credenziali (V5, V6).

La memorizzazione di credenziali in chiaro all'interno di file di backup lasciati nella document root del server, unitamente al riutilizzo delle medesime credenziali (o di credenziali riconducibili al medesimo schema) tra il livello applicativo e il livello di sistema operativo, costituisce una violazione del principio del minimo privilegio e del principio di segregazione delle identità. Tale condizione ha permesso un movimento laterale (lateral movement) pressoché immediato dal contesto applicativo (www-data) al contesto di un utente di sistema con accesso interattivo (jangow01).

### Rischio infrastrutturale (V7).

L'assenza di un processo strutturato di patch management ha lasciato in esecuzione una versione del kernel Linux affetta da una vulnerabilità nota e pubblicamente documentata, la cui correzione era disponibile da tempo al momento dell'esercitazione simulata. Tale circostanza dimostra come la sicurezza applicativa, per quanto rafforzata, non possa mai considerarsi disgiunta dalla sicurezza dello strato di sistema operativo e da un ciclo di aggiornamento tempestivo.

## 10.3 Contromisure Proposte

| Area                        | Contromisura                                                                                                                                | Priorità |
|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|----------|
| Configurazione Web Server   | Disabilitazione del directory listing (direttiva Options -Indexes in Apache)                                                                | Alta     |
| Gestione dei File Sensibili | Rimozione di file di backup/temporanei/di configurazione dalla document root pubblica; memorizzazione delle credenziali fuori dalla webroot | Critica  |

| Area                       | Contromisura                                                                                                                                                                                   | Priorità |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|
| Validazione dell'Input     | Controlli rigorosi di validazione e sanitization per ogni input destinato a funzioni di esecuzione comandi; eliminazione di shell_exec()/system()/exec(); whitelisting dei parametri accettati | Critica  |
| Gestione degli Errori      | display_errors = Off in produzione; gestione centralizzata delle eccezioni con logging server-side e messaggi generici lato client                                                             | Alta     |
| Gestione delle Identità    | Credenziali distinte e non riutilizzate tra servizi e sistema operativo; rotazione periodica; MFA e sostituzione di FTP con SFTP/FTPS                                                          | Alta     |
| Patch Management           | Processo strutturato di aggiornamento, con priorità al kernel e ai componenti critici; vulnerability scanning periodico                                                                        | Critica  |
| Segregazione dei Privilegi | Principio del minimo privilegio per le utenze di servizio (es. www-data); restrizione delle capacità di esecuzione comandi                                                                     | Alta     |
| Monitoraggio e Rilevamento | Logging e monitoring centralizzato (SIEM) per pattern anomali tipici di command injection                                                                                                      | Media    |
| Architettura Zero Trust    | Segmentazione di rete, autenticazione e autorizzazione di ogni richiesta, ispezione del traffico interno (East-West)                                                                           | Media    |

## 10.4 Considerazioni sulla Resilienza Complessiva

L'esercitazione conferma un principio cardine della sicurezza informatica: la robustezza di un sistema è determinata dall'anello più debole della catena di controlli. Nel caso analizzato, la compromissione totale del sistema non è stata il risultato di un singolo difetto grave, bensì della concatenazione di più vulnerabilità di severità individualmente moderata. Tale osservazione avvalorava l'approccio della defense in depth, secondo cui la sicurezza deve essere garantita attraverso strati multipli e indipendenti di controllo, in modo che il fallimento di una singola misura non comprometta l'intera infrastruttura.

## 11. Mappatura delle Tecniche secondo il Framework MITRE ATT&CK

Al fine di inquadrare l'attività svolta entro un framework di riferimento riconosciuto a livello internazionale, si riporta di seguito la mappatura delle tecniche impiegate secondo la matrice MITRE ATT&CK:

| Fase                       | Tecnica MITRE ATT&CK                        | ID        |
|----------------------------|---------------------------------------------|-----------|
| Ricognizione               | Active Scanning: Scanning IP Blocks         | T1595.001 |
| Ricognizione               | Gather Victim Network Information           | T1590     |
| Accesso Iniziale           | Exploit Public-Facing Application           | T1190     |
| Esecuzione                 | Command and Scripting Interpreter           | T1059     |
| Scoperta Credenziali       | Unsecured Credentials: Credentials In Files | T1552.001 |
| Movimento Laterale/Accesso | Valid Accounts                              | T1078     |
| Escalation dei Privilegi   | Exploitation for Privilege Escalation       | T1068     |

## 12. Considerazioni Finali e Lezioni Apprese

L'esercitazione condotta ha permesso di ripercorrere, in un ambiente sicuro e controllato, l'intero ciclo di vita di un attacco informatico, dalla fase di ricognizione iniziale fino al conseguimento del pieno controllo amministrativo del sistema target. Il valore didattico dell'attività risiede non tanto nella singola tecnica di exploitation impiegata, quanto nella comprensione della logica concatenata che lega vulnerabilità apparentemente isolate in un percorso di compromissione coerente e progressivo.

Tra le principali lezioni apprese si segnalano:

- L'importanza della minimizzazione della superficie di attacco, attraverso la disabilitazione di funzionalità non necessarie (directory listing) e la rimozione di file residui privi di finalità operativa (backup, file temporanei).
- La centralità della validazione dell'input in qualunque componente applicativo che interagisca, anche indirettamente, con il sistema operativo sottostante.
- La necessità di non riutilizzare credenziali tra contesti differenti (applicativo, database, sistema operativo), pratica che amplifica in modo esponenziale l'impatto di una singola compromissione.
- La rilevanza di un processo di patch management strutturato, in assenza del quale anche un'infrastruttura applicativa correttamente configurata rimane esposta a compromissione totale tramite vulnerabilità del sistema operativo.
- Il valore metodologico di un approccio sistematico e documentato, che consente non solo di riprodurre l'attacco a fini di verifica, ma anche di tradurre ciascuna fase in una corrispondente raccomandazione difensiva.

In conclusione, l'esercitazione ha dimostrato in maniera empirica come la sicurezza informatica non possa essere ricondotta all'adozione di singole misure isolate, bensì debba essere concepita come un processo continuo, integrato e multilivello, in cui la sicurezza applicativa, la gestione delle identità e la manutenzione dell'infrastruttura di sistema concorrono, in egual misura, alla resilienza complessiva dell'organizzazione. La capacità di un analista di sicurezza di ricostruire, comprendere e comunicare tale catena di causalità costituisce, in ultima analisi, il principale risultato formativo conseguito attraverso la presente attività di penetration testing.

## 13. Riferimenti Bibliografici

8. MITRE ATT&CK® Framework, Enterprise Matrix, disponibile su: <https://attack.mitre.org>
9. MITRE Corporation, Common Weakness Enumeration (CWE), disponibile su: <https://cwe.mitre.org>
10. OWASP Foundation, OWASP Top Ten Project e Testing Guide, disponibile su: <https://owasp.org>
11. The Penetration Testing Execution Standard (PTES), disponibile su: <http://www.pentest-standard.org>
12. Exploit Database, Exploit-DB 45010 – Linux Kernel BPF Privilege Escalation, disponibile su: <https://www.exploit-db.com>

13. MITRE Corporation, CVE-2017-16995, National Vulnerability Database, disponibile su:  
<https://nvd.nist.gov>
14. Documentazione ufficiale Apache HTTP Server, disponibile su:  
<https://httpd.apache.org/docs/>
15. Documentazione ufficiale PHP, sezione Error Handling and Logging, disponibile su:  
<https://www.php.net/manual/en/book.errorfunc.php>
16. Materiale didattico di riferimento del corso: Analisi delle Minacce Cyber: Tendenze, Vulnerabilità e Strategie di Difesa 2024–2025, documento fornito a supporto dell'inquadramento teorico dell'esercitazione.

---

*Documento redatto esclusivamente per finalità didattiche e di analisi tecnica in ambiente di laboratorio controllato.  
Nessuna informazione contenuta nella presente relazione è riferita a sistemi di produzione o a infrastrutture reali di terze parti.*